

웹 애플리케이션 취약점 분석 보고서

Nikto 자동 스캔 결과 및 OWASP Top 10 기반 자가점검

문서번호	WA-2026-0706-01	작성일	2026-07-06
대상	queue-gate(172.16.60.146)로 서빙되는 예매 페이지 및 /api/ 엔드포인트	버전	1.1 (2026-07-07, A02/A07 개정 — AUTH-2026-0707-01 반영)
점검 방식	자동 스캔(Nikto) + 소스 코드 기반 자가점검	기준	OWASP Top 10:2021

1. 개요

본 보고서는 앞선 모의해킹 결과 보고서(PT-2026-0706-01)에서 네트워크 계층(nmap) 점검과 함께 다뤘던 웹 애플리케이션 취약점 점검 내용을 별도로 심화한 문서다. Nikto 자동 스캔 결과에 더해, OWASP Top 10 항목별로 실제 코드와 설정을 대조하는 자가점검을 수행하여 "스캐너가 발견한 것"과 "실제상 방어되는 것"을 함께 정리했다.

2. Nikto 자동 스캔 결과

2.1 1차 스캔

```
$ nikto -h http://172.16.60.146

+ Server: nginx/1.28.3 (Ubuntu)
+ [013587] /: Suggested security header missing: permissions-policy
+ [013587] /: Suggested security header missing: strict-transport-security
+ [013587] /: Suggested security header missing: x-content-type-options
+ [013587] /: Suggested security header missing: referrer-policy
+ [013587] /: Suggested security header missing: content-security-policy
+ 8229 requests: 0 errors and 22 items reported on the remote host
```

2.2 조치

```
sudo vi /etc/nginx/conf.d/queue.conf
# location / 블록 앞에 추가
add_header X-Content-Type-Options "nosniff" always;
add_header Referrer-Policy "strict-origin-when-cross-origin" always;
add_header Permissions-Policy "geolocation=(), microphone=()" always;
add_header Content-Security-Policy "default-src 'self'" always;

sudo nginx -t
sudo systemctl restart nginx
```

2.3 2차 스캔 (조치 후)

```
$ nikto -h http://172.16.60.146

+ [013587] /: Suggested security header missing: strict-transport-security
+ (permissions-policy, referrer-policy, content-security-policy 미보고 — 조치 반영 확인)
+ 8229 requests: 0 errors and 20 items reported on the remote host
```

2.4 헤더 반영 현황

헤더	1차	2차(조치 후)	비고
Content-Security-Policy	누락	반영됨	-
Referrer-Policy	누락	반영됨	-
Permissions-Policy	누락	반영됨	-
X-Content-Type-Options	누락	누락	설정 파일에 지시어를 추가했으나 2차 스캔에서도 미반영으로 확인됨. Nginx reload 누락 또는 위치 오기재 가능성 — 재확인 필요
Strict-Transport-Security	누락	누락	TLS(443) 미적용 상태와 연동된 항목. 인증서 적용 후 함께 반영 예정

5개 항목 중 3개는 조치가 확인되었고, 2개는 미해결 상태로 남아 있다. X-Content-Type-Options는 설정 지시어 자체는 추가했으나 실제 응답에는 반영되지 않아, 원인 재조사가 필요한 항목으로 구분했다.

2.5 오탐 처리

Nikto가 함께 보고한 아래 항목들은 범용 취약점 데이터베이스를 기계적으로 대조한 결과로, 현재 스택 (Nginx 정적 서빙 + Node.js API)에 실재하지 않는 오탐으로 판단하여 조치 대상에서 제외했다.

- Vignette CMS, Cisco HTTP 서비스, FrontPage, CCBill 관련 파일/경로 존재 추정 항목 — 해당 소프트웨어를 사용하지 않음
- iisamples, exair 등 IIS 계열 스크립트 관련 항목 — IIS를 사용하지 않음
- 디렉터리 존재 추정성 안내(/bank/, /java/, /purchase/ 등) — 실제 해당 경로 없음, 404 정상 응답

3. OWASP Top 10:2021 기반 자가점검

Nikto와 같은 자동 스캐너는 응답 헤더나 알려진 경로 패턴을 점검할 수 있지만, 인증/인가 로직이나 동시성 제어 같은 애플리케이션 고유 로직의 안전성은 코드 검토로만 확인할 수 있다. 아래는 구현된 코드와 설계 문서를 근거로 OWASP Top 10 각 항목에 대한 현재 상태를 정리한 것이다.

항목	위협 분류	상태	근거 / 비고
A01	Broken Access Control	부분 구현	마이페이지는 주문 데이터에 ownerEmail을 기록하고 로그인 사용자 소유만 필터링하도록 프론트엔드에 구현했으나, 실제 인증 세션과 연동된 백엔드 검증은 아직 없다. 관리자 대시보드는 필터 없이 전체 데이터를 조회하도록 의도적으로 설계했다(권한별 접근범위 대조 목적)
A02	Cryptographic Failures	구현·검증 완료	회원가입 API에서 비밀번호를 bcrypt(cost 12)로 해시 저장하도록 구현하고, DB 직접 조회로 평문이 어디에도 없음을 확인했다(AUTH-2026-0707-01). TLS는 여전히 인증서 미적용으로 443 포트가 closed 상태다(2장 nmap 결과 참고)
A03	Injection	구현·부분 검증	예약 API(server.js)는 mysql2의 파라미터 바인딩(? 플레이스홀더)만 사용하며 문자열 결합으로 쿼리를 구성하는 부분이 없다. 다만 sqlmap을 이용한 실제 침투 테스트는 적합한 파라미터 기반 엔드포인트 부재로 보류된 상태다
A04	Insecure Design	구현·검증 완료	좌석 동시 예약(Race Condition)은 Redis 원자연산으로 구조적으로 차단했으며, K6 100건 동시요청 검증(CT-2026-0706-01)에서 중복예약 0건을 확인했다
A05	Security Misconfiguration	부분 구현	ufw 최소권한 화이트리스트는 nmap으로 실증 확인(PT-2026-0706-01). 보안 헤더는 5개 중 3개만 반영 확인(본 문서 2.4). Nginx 기본 페이지 노출 문제는 sites-enabled/default 제거로 해결함(TS-2026-0706-01 5장)
A06	Vulnerable and Outdated Components	미점검	Node.js 및 npm 패키지에 대한 npm audit 등 의존성 취약점 스캔을 수행하지 않았다. 후속 점검 필요 항목으로 남긴다
A07	Identification and Authentication Failures	부분 구현·검증 완료	회원가입·로그인·비밀번호 변경 API를 실제 구현하고, bcrypt 해시 저장·로그인 실패 5회 시 Redis 기반 423 잠금을 검증했다(AUTH-2026-0707-01). 관리자 계정에는 TOTP MFA 대신 chage 기반 90일 만료 정책을 적용했다. 다만 세션 쿠키 보안속성 확인, 비밀번호 재사용 금지, HIBP 유출 확인, Hydra 실증 테스트는 아직 남아있다
A08	Software and Data Integrity Failures	평가 범위 밖	CI/CD 파이프라인이나 서드파티 패키지 무결성 검증 체계를 구축하지 않아 본 세션의 평가 범위에 서 제외했다
A09	Security Logging and Monitoring Failures	부분 구현·검증 완료	Suricata를 queue-gate에 배치해 예약 API 대상 반복 요청을 실시간 탐지하도록 구현하고 실제 공격 시뮬레이션으로 탐지를 확인했다(IDS-2026-0706-01). 다만 로그를 중앙화하는 ELK 연동은 보류 상태다
A10	Server-Side Request Forgery	해당 없음	현재 애플리케이션에 외부 URL을 서버가 대신 요청하는 기능이 없어 해당 위협 자체가 성립하지 않는다

4. 종합 평가

구분	해당 항목
구현 및 검증 완료	A02(비밀번호 암호화 저장), A04(동시성 제어), A09(실시간 탐지) — 실측 데이터로 뒷받침됨
부분 구현	A01(접근제어, 백엔드 미연동), A03(Injection 방어, 침투테스트 미실시), A05(보안설정, 헤더 2개 미해결), A07(인증, 세션·MFA·재사용방지 남음)
미구현	없음 (TLS 적용 등은 A02/A05 하위 세부 항목으로 관리)
평가 범위 밖 / 해당 없음	A06(의존성 스캔 미실시), A08(공급망 무결성), A10(SSRF 해당 기능 없음)

5. 우선순위별 조치 권고

1. (높음) X-Content-Type-Options 헤더 미반영 원인 재조사 — 설정은 추가했으나 실제 응답에 반영되지 않은 원인을 확인하고 3차 Nikto 재검증을 수행한다.
2. (높음) IDOR(접근제어) 테스트 — 계정 A/B를 생성해 서로의 주문 데이터에 교차 접근이 차단되는지 검증한다(A01 항목 완료 전환의 마지막 단계).
3. (중간) 세션 쿠키 보안속성 및 Hydra 실증 테스트 — HttpOnly/Secure/SameSite 속성 확인과 무차별 대입 방어 실측 검증으로 A07을 완료 상태로 전환한다.
4. (중간) TLS 적용 및 HSTS 반영 — 인증서 발급 후 443 포트를 open으로 전환하고 HSTS 헤더를 추가한다.

5. (중간) **sqlmap 기반 Injection 실증 테스트** — 파라미터 기반 엔드포인트(좌석 조회 등)를 확장 구현한 뒤 실제 침투 테스트로 A03 항목을 검증 완료 상태로 전환한다.
6. (낮음) **npm audit 등 의존성 취약점 점검(A06) 추가** — 정기 점검 항목으로 편입한다.

작성: 최시은

검토: -

배포: 내부 참고용